RESULTADO DA COMPARAÇÃO — TESTE 04

- **Imagem analisada:** fiware/orion (Debian 13.4, amd64)
- **Scanner:** Trivy 0.74.0
- **Fonte de dados:** `TRIVY_FIWARE_ORION_HIGH_CRITICAL_TESTE04.json`
- **Relatórios avaliados:** `TESTE03 - Granite4.2.pdf`, `TESTE03 - Deepseek-r1.pdf`, `TESTE03 - Qwen3.5.pdf`, `TESTE04 - GPT-6-astra-alto.pdf`
- **Data da avaliação:** 19/10/2026

---

0. Escopo, método e condições do experimento

0.1 Objetivo

Comparar o nível de qualidade das análises produzidas por três modelos locais (Granite 4.2, DeepSeek R1 e Qwen 3.5) com a análise produzida por um modelo de nuvem de alto nível (GPT-6 Astra Alto), usando como critérios exatamente os três elementos do prompt base:

1. Vulnerabilidades relevantes (ID e pacote);
2. Impacto provável;
3. Recomendações de correção práticas.

Cada critério recebe nota de 0 a 10. A média aritmética simples dos três define o resultado do modelo. Considera-se satisfatório média maior ou igual a 7,00.

0.2 Regras seguidas

- Nenhuma fonte externa foi consultada. Todas as verificações de IDs, pacotes, versões, status de correção, descrições e metadados da imagem foram feitas exclusivamente contra o JSON do Trivy.
- Tamanho de relatório não foi usado como medida de qualidade, nem para cima nem para baixo.
- Os critérios e a escala foram mantidos idênticos para os quatro modelos.
- As avaliações individuais foram construídas antes de qualquer comparação.

0.3 Dados de referência extraídos do JSON

Item	Valor no JSON
Ocorrências HIGH + CRITICAL	832
Ocorrências HIGH	820
Ocorrências CRITICAL	12
CVEs distintos	744
Pacotes afetados	34
Ocorrências com `FixedVersion` informada	714
Ocorrências sem `FixedVersion` (status `affected` ou `fix_deferred`)	118
Ocorrências em `linux-libc-dev`	695 (7 CRITICAL; 71 sem correção)
Arquitetura da imagem	amd64
Usuário configurado na imagem	nobody

Item	Valor no JSON
Entrypoint	/usr/bin/contextBroker
Porta exposta	1026/tcp

Distribuição das 12 CRITICAL: 7 em `linux-libc-dev`, 3 em `perl-base` (CVE-2026-13221, CVE-2026-42496, CVE-2026-8376) e 2 em `libgnutls30t64` (CVE-2026-33845, CVE-2026-42010).

Pacotes não kernel com vulnerabilidades HIGH/CRITICAL: família util-linux (9 pacotes, 8 CVEs cada, 4 sem correção), perl-base (8), curl e libcurl4t64 (7, 2 sem correção), libgnutls30t64 (5), libpcre2-8-0 (4), libssh2-1t64 (4), openssl/libssl3t64/openssl-provider-legacy (3), família krb5 (5 pacotes, 2 CVEs), libsqlite3-0 (2), gzip (1), libcap2 (1), libnghttp2-14 (1), libacl1 (1, sem correção), libsystemd0 e libudev1 (1, sem correção), libtinfo6/ncurses-base/ncurses-bin (1, sem correção).

0.4 Diferença entre as condições de entrada — ponto central para a leitura dos resultados

Os quatro relatórios **não** foram produzidos sob a mesma condição experimental, e a diferença é maior do que apenas "em partes" versus "em uma única chamada":

- **Modelos locais (Teste 03):** os três relatórios registram no cabeçalho "Blocos analisados: 11" e "Vulnerabilidades descartadas (FIXED): 654". Ou seja, o pipeline do Teste 03 **removeu todas as vulnerabilidades que já tinham correção informada** e entregou aos modelos apenas as ocorrências sem correção, em 11 blocos de aproximadamente 10 ocorrências cada. Isso é confirmado pelo conteúdo: os IDs citados pelos modelos locais correspondem às vulnerabilidades com status `affected`/`fix_deferred` no JSON do Teste 04 (ou a vulnerabilidades do kernel que só receberam correção, em 6.12.113-1, depois do Teste 03). Consequências diretas:
- os modelos locais **nunca viram** as 12 CRITICAL de gnutls e perl, nem openssl, pcre2, sqlite, libssh2, krb5, nghttp2, gzip ou libcap2;
- os modelos locais **não tinham o campo `FixedVersion` preenchido** em nenhuma entrada, logo não podiam citar versões corrigidas;
- os modelos locais não tinham visão da imagem como um todo, nem de totais, nem de quais pacotes concentravam os achados.
- **GPT-6 Astra Alto (Teste 04):** recebeu o JSON completo com 832 ocorrências HIGH/CRITICAL, incluindo as corrigidas, com `FixedVersion`, metadados da imagem (arquitetura, usuário, entrypoint) e tudo em uma única análise.

Portanto, ao longo desta avaliação:

- não se penaliza nenhum modelo local por não citar versões de correção, totais, CRITICAL de gnutls/perl ou qualquer informação que não estava em seu bloco;
- não se penaliza a ausência de priorização global entre blocos, pois cada bloco foi uma chamada isolada;
- avalia-se **a qualidade do que cada modelo fez com o que recebeu**: fidelidade aos dados do bloco, coerência da interpretação, controle de inferência, utilidade das recomendações e tratamento das vulnerabilidades sem correção (que eram, no caso dos locais, todas).

Os relatórios locais apresentam a resposta de cada parte em sequência ("Parte 1 de 11" até "Parte 11 de 11"), sem etapa de consolidação. A avaliação considera essa estrutura e lê cada parte como uma resposta ao mesmo prompt base aplicado a um subconjunto dos dados.

0.5 Verificação de IDs citados

Todos os IDs CVE citados pelos quatro relatórios foram cruzados com o JSON. Resultado:

Relatório	IDs distintos citados	Existentes no JSON	Inexistentes no JSON
Granite 4.2	72	72	0
DeepSeek R1	52	52	0
Qwen 3.5	46	46	0
GPT-6 Astra Alto	30	30	0

Nenhum modelo inventou um identificador. A precisão, portanto, foi avaliada no nível seguinte: associação ID-pacote, descrição do problema, impacto atribuído e recomendação.

ETAPA 1 — AVALIAÇÃO INDIVIDUAL DO MODELO DE NUVEM

GPT-6 Astra Alto

Critério	Nota
Vulnerabilidades relevantes	8/10
Impacto provável	9/10
Recomendações de correção	9/10
MÉDIA	**8,67/10**

Principais acertos

- **Totais exatos.** O relatório afirma 832 ocorrências, 820 HIGH, 12 CRITICAL, 744 CVEs distintos, 714 com versão de correção e 118 sem. Todos os seis números conferem com o JSON.
- **As 12 CRITICAL foram todas identificadas**, com pacote correto: as 7 do kernel (CVE-2026-43011, 43037, 43185, 53215, 63825, 90037, 93221), as 3 de perl-base e as 2 de libgnutls30t64. Nenhuma CRITICAL ficou de fora.
- **Associação ID-pacote correta em todos os 30 IDs citados.** Inclusive em casos sutis, como listar `libssl3t64`, `openssl` e `openssl-provider-legacy` como os três pacotes da mesma origem OpenSSL, e `curl` com `libcurl4t64`.
- **Descrições fiéis ao texto do JSON.** Exemplos verificados: CVE-2026-33845 ("indisponibilidade e possível vazamento de dados por fragmentos DTLS malformados") corresponde à descrição de leitura fora dos limites com divulgação de informação ou DoS; CVE-2026-42010 ("contornar autenticação em servidores RSA-PSK") corresponde à descrição; CVE-2026-6276 e CVE-2026-8927 (vazamento de cookies e cabeçalho Proxy-Authorization ao reutilizar handles) correspondem; CVE-2026-13221 ("pode invalidar filtros baseados em expressões regulares muito grandes") é uma leitura correta de "silently incorrect regular expression matches".
- **Uso correto do campo `FixedVersion`**, inclusive quando as CVEs de um mesmo pacote têm versões de correção diferentes: para OpenSSL, as três CVEs têm correção em 3.5.6-1~deb13u2, 3.5.7-1~deb13u2 e 3.5.7-1~deb13u3; o relatório recomenda a maior delas, 3.5.7-1~deb13u3, "contemplando as correções listadas". Para curl, recomenda 8.14.1-2+deb13u7, que cobre tanto as corrigidas em deb13u4 quanto em deb13u7. Para pcre2, recomenda 10.46-1~deb13u3, que cobre as duas citadas.
- **Separação explícita entre o que tem e o que não tem correção**, com mitigação específica para os casos sem correção: CVE-2026-12064 e CVE-2026-8458 (curl) e CVE-2026-76642 e CVE-2026-78410 (util-linux) são

marcadas como "não têm correção indicada", e as mitigações propostas derivam diretamente das descrições (usar esquema explícito em URLs SFTP/SCP; evitar reutilizar conexões Negotiate entre serviços distintos; restringir montagens por usuário e remover SUID desnecessário).

- **Contextualização com metadados da imagem.** Observa que a imagem é amd64 e que CVE-2026-8376 descreve overflow em builds de 32 bits, logo "sua aplicabilidade precisa ser confirmada". Observa que o usuário `nobody` já está configurado (confere com `config.User` no JSON). Observa que `linux-libc-dev` é pacote de desenvolvimento e que seu registro "não comprova exposição do kernel em execução", recomendando validar o host separadamente e remover o pacote da imagem se dispensável.
- **Controle de inferência explícito:** "A presença do pacote não comprova exploração no Orion"; "O impacto depende do uso desses recursos"; "campo vazio não prova inexistência de patch"; "As versões acima são as informadas no JSON, sem validação externa"; "Seleção priorizada; não é uma reprodução integral dos achados".

Principais limitações

- **Omissões entre as vulnerabilidades sem correção.** Das 4 CVEs sem correção da família util-linux, o relatório cita apenas 2 (CVE-2026-76642 e CVE-2026-78410) e omite CVE-2026-78408 (nsenter --join-cgroup) e CVE-2026-78409 (X-mount.subdir). Também omite CVE-2026-54369 (libacl1), CVE-2026-16742 (libsystemd0/libudev1), CVE-2025-69720 (ncurses) e CVE-2026-9538 (perl-base, status `fix_deferred`), todas HIGH e todas sem correção. Vulnerabilidades sem correção são justamente as que mais precisam de mitigação explícita, então essas omissões pesam mais do que a omissão de itens corrigidos pela mesma versão.
- **Pacotes HIGH não mencionados:** krb5 (5 pacotes, 2 CVEs de DoS remoto não autenticado), libnghttp2-14 (DoS por quadros HTTP/2 malformados, relevante para um broker HTTP que depende de libcurl), gzip e libcap2. Todos têm correção informada, mas não entram na ação de reconstrução recomendada de forma nominal.
- **Lacuna de versão em libssh2.** O relatório cita CVE-2026-55200 e a correção 1.11.1-1+deb13u1. Porém CVE-2026-58050, no mesmo pacote, só é corrigida em 1.11.1-1+deb13u2. Um leitor que aplicasse apenas a versão citada deixaria uma HIGH aberta. O relatório não afirma que u1 cobre todas, mas também não alerta.
- **Kernel tratado apenas de forma agregada.** Para as 695 ocorrências de `linux-libc-dev` não há versão de correção citada (o JSON informa correções em 6.12.85-1, 6.12.94-1, 6.12.111-1 e outras para 624 delas) nem indicação de quantas estão sem correção (71). A recomendação de remover o pacote e validar o host é tecnicamente sólida, mas a informação quantitativa estava disponível e não foi usada.
- **Resumo sintético dos CRITICAL do kernel.** As sete CRITICAL do kernel são apenas enumeradas, com a frase genérica "as descrições incluem corrupção de memória e falhas de concorrência". É correto, mas não distingue, por exemplo, que CVE-2026-43185 descreve heap overflow em ksmbd acionável por mensagem maliciosa, enquanto CVE-2026-63825 trata de instrumentação gcov.

Qualidade da interpretação

Alta. O impacto atribuído a cada CVE deriva do texto do JSON, sem inflar. Onde a descrição diz DoS ou vazamento, o relatório diz DoS ou vazamento; onde diz execução de código (sqlite FTS5, libssh2, OpenSSL PKCS7), o relatório diz execução de código. A proporcionalidade é mantida: CVEs com pré-condição (RSA-PSK, DTLS, QUIC, builds de 32 bits, SUID/fstab) recebem a ressalva correspondente. O relatório também compreende o contexto de imagem de contêiner: distingue o pacote de headers do kernel em execução, usa o usuário `nobody` e a arquitetura como dados de contexto, e enquadra a correção como reconstrução da imagem seguida de nova varredura.

Qualidade das recomendações

Alta. As recomendações são específicas (pacote + versão exata do JSON), aplicáveis a uma imagem Debian (reconstruir, testar, varrer novamente) e tratam separadamente os casos sem correção com mitigações derivadas

das descrições. A observação sobre preservar o epoch dos pacotes util-linux (`login` tem versão instalada 1:4.16.0-2+really2.41-5) é um detalhe operacional relevante. Limitações: ausência de recomendações nominais para os pacotes omitidos e a lacuna u1/u2 em libssh2.

Informações não sustentadas

Não foi encontrada afirmação técnica contrariada pelo JSON. Todas as versões, status, pacotes e totais conferem. A única inferência não literal é a de que CVE-2026-13221 "pode invalidar filtros baseados em expressões regulares", que é uma consequência plausível e marcada com "pode". A nota final sobre o caminho de subpastas não existir é informação de processo, não técnica.

Síntese

O relatório do GPT-6 Astra Alto é preciso, contextualizado e controlado nas inferências. Cobre todas as CRITICAL e a maior parte das famílias de pacotes com maior impacto, com versões corretas do JSON e tratamento diferenciado para o que não tem correção. Sua principal fragilidade é a cobertura seletiva entre as HIGH sem correção e entre pacotes de menor volume, o que impede a nota máxima no critério de vulnerabilidades. Média 8,67, acima do limiar satisfatório.

ETAPA 2 — AVALIAÇÃO INDIVIDUAL DOS MODELOS LOCAIS

Observação válida para os três modelos: o insumo de cada parte era um bloco de aproximadamente 10 ocorrências sem `FixedVersion`. Os blocos 1 a 3, 10 e 11 continham sobretudo util-linux, curl, libacl1, systemd, ncurses e perl; os blocos 4 a 10 eram majoritariamente `linux-libc-dev`. Vários IDs se repetem entre blocos porque a mesma CVE afeta até 9 pacotes da família util-linux.

Granite 4.2

Critério	Nota
Vulnerabilidades relevantes	7/10
Impacto provável	6/10
Recomendações de correção	5/10
MÉDIA	**6,00/10**

Principais acertos

- **Cobertura completa dentro de cada bloco.** Em todas as 11 partes o modelo lista todos os IDs presentes no bloco, com o pacote correto conforme o campo `PkgName`. Foram 72 IDs distintos citados, todos existentes no JSON.
- **Tratamento explícito de duplicatas.** Reconhece que a mesma CVE aparece sob vários pacotes da família util-linux e consolida por ID, informando os pacotes afetados. Na parte 10 identifica corretamente que as entradas de `mount` repetem as de `login`.
- **Proporcionalidade em vários trechos.** Parte 3: "Todos os casos são HIGH e exploráveis localmente sem acesso remoto" (correto para util-linux, systemd-homed e ncurses). Parte 4: "RISCO LOCAL". Parte 7: "Não há indicação de exploração direta sem cenários de depuração/corrida" (coerente com descrições que mencionam KASAN e CONFIG_MEM_ALLOC_PROFILING_DEBUG).

- **Única leitura de contexto de contêiner entre os locais.** Parte 7: "Se o container usa o kernel do hospedeiro (caso mais comum), garantir que o hospedeiro esteja patchado, não depender de atualizações dentro do container apenas". Essa é a mesma distinção que o GPT faz sobre `linux-libc-dev` e é tecnicamente a observação mais importante sobre as 695 ocorrências do kernel.
- **Mitigações derivadas das descrições:** evitar URLs sem esquema com `--proto-default` para SFTP/SCP (CVE-2026-12064); auditar `/etc/fstab` e remover opções `X-mount.*` para caminhos não confiáveis; executar serviços sem root; isolar o serviço em contêiner sem montagens do host.
- **Versões extraídas corretamente quando a descrição as traz:** libacl ≥ 2.4.0, ncurses 6.5-20251213, Archive::Tar 3.10 (partes 1, 3, 11).

Principais limitações

- **Erro de lógica na parte 8.** O modelo interpreta a frase padrão "the following vulnerability has been resolved" (presente em todas as descrições de CVE do kernel) como indício de que a versão instalada 6.12.74-2 já contém as correções, e conclui: "Todas as CVE listadas são fixes já resolvidos no kernel; ação prática é garantir que a versão instalada reflita esses fixes". Isso inverte o sentido do dado: o Trivy listou essas CVEs justamente porque a versão instalada é vulnerável e não há correção informada. A recomendação resultante ("verificar patch atual", "atualizar se necessário") perde urgência.
- **Versões inventadas ou sem sustentação:** "util-linux ≥ 2.42.3" (parte 3), "util-linux 2.41.6" (parte 11), "kernel 6.5+" como alvo de atualização para um kernel 6.12 (parte 9), "linux-libc-dev ≥ 6.12.74-2+fixes e login ≥ 1:4.16.0-2+really2.42+" (parte 10), "versão pós-patch 6.12.74-x" (parte 5). Nenhuma dessas versões está no JSON, e a parte 10 ainda afirma que "Debian 13.4 já inclui fixes para esses CVEs nas versões atualizadas", o que contradiz o status `affected` dos dados.
- **Orientações tecnicamente incorretas:** "Preferir AT_SYMLINK_FOLLOW em vez de AT_SYMLINK_NOFOLLOW para montagens críticas" (parte 4) inverte a lógica da descrição de CVE-2026-78409; "Desative o uso de lockdown de PCI/legacy I/O" (parte 9) recomenda remover a proteção que a CVE-2026-90315 diz estar incompleta; "no_new_perm" (parte 4) não é uma opção existente.
- **Confusão de release:** chama Debian 13.4 de "Bookworm" nas partes 5 e 9. O JSON informa apenas "debian 13.4"; o nome é conhecimento externo e, além disso, errado.
- **Recomendações de teste desproporcionais ao contexto:** sugerir validar o Orion com "streaming áudio USB, operações CXL, criação/destruição de grupos via ioctl" (parte 6) ou "GPU DMA, timer POSIX" (parte 9) ignora que o alvo é um broker de contexto em contêiner.
- **Caminhos e procedimentos inventados:** "/var/log/orion/" (parte 8).
- **Legibilidade comprometida.** O relatório contém, antes de cada resposta, o raciocínio interno do modelo em inglês ("Okay, the user wants me to...") e, em várias partes, dois ou três rascunhos da resposta antes da versão final. Isso não altera a nota dos três critérios, mas prejudica a capacidade de destacar os achados, exigida no critério 1, e será tratado na seção de concisão.

Qualidade da interpretação

Mista. Quando o modelo lê a descrição, tende a resumi-la com fidelidade e a classificar corretamente o vetor como local. Os problemas surgem quando o modelo tenta ir além do dado: trata boilerplate como evidência de correção (parte 8), introduz versões e nomes de release de memória, e produz orientações invertidas. Há leitura de contexto de contêiner valiosa na parte 7, mas ela não se repete nas demais partes, que tratam `linux-libc-dev` como se fosse o kernel em execução dentro do contêiner.

Qualidade das recomendações

Irregular. As boas recomendações (auditoria de fstab, esquema explícito em URLs, isolamento em contêiner, patch no host) são práticas e sustentadas. Mas o conjunto é diluído por versões fictícias, orientações tecnicamente

erradas, procedimentos de teste fora do contexto e, na parte 10, pela afirmação falsa de que as correções já existem no Debian 13.4. Em nenhuma parte o modelo diz com clareza "o dado não informa versão corrigida", que seria o tratamento adequado para um bloco composto apenas de vulnerabilidades sem correção.

Informações não sustentadas

- Versões: 2.42.3, 2.41.6, "kernel 6.5+", "6.12.74-2+fixes", "1:4.16.0-2+really2.42+", "6.12.74-x".
- "Debian 13.4 já inclui fixes para esses CVEs" (parte 10) e "as vulnerabilidades são já cobertas por releases seguras do Debian".
- "Debian Bookworm" para 13.4.
- "Todas as CVE listadas são fixes já resolvidos no kernel" (parte 8).
- "A versão 6.12.74-2 está já comprometida" (parte 6): o dado diz vulnerável, não comprometida.
- "AT_SYMLINK_FOLLOW", "no_new_perm", "/var/log/orion/".

Síntese

O Granite 4.2 identifica e associa corretamente tudo o que recebeu e, em alguns trechos, demonstra a leitura de contexto mais madura entre os locais. Porém, suas recomendações contêm versões e orientações sem sustentação nos dados, e a parte 8 inverte o sentido do status das vulnerabilidades. O relatório expõe raciocínio e rascunhos, o que afasta o resultado do pedido de concisão. Média 6,00, abaixo do limiar satisfatório.

DeepSeek R1

Critério	Nota
Vulnerabilidades relevantes	6/10
Impacto provável	5/10
Recomendações de correção	5/10
MÉDIA	**5,33/10**

Principais acertos

- **IDs e pacotes corretos em tudo o que foi citado.** 52 IDs distintos, todos existentes no JSON, com `PkgName` correto, inclusive nas variações de pacote da família util-linux (bsdutils, libblkid1, libmount1, libsmartcols1, libuuid1, login, mount, util-linux).
- **Priorização explícita nos blocos mistos.** Parte 2 conclui recomendando priorizar util-linux (CVE-2026-78410, 78408, 78409, 76642) "devido à sua natureza de acesso e modificação de sistema", seguida de libcurl. Parte 11 separa "Vulnerabilidades Relevantes" (util-linux) de "Outras Vulnerabilidades (Menos Relevantes para o Orion)" (perl, ncurses), com justificativa de contexto ("requer um contexto Perl ativo", "menos direta para o Orion").
- **Paráfrases fiéis em várias partes.** Parte 2 descreve corretamente os quatro CVEs de util-linux e os dois de curl. Parte 6 mapeia cada um dos 10 CVEs do kernel ao subsistema correto (SVE, ALSA usb-audio, CXL, RDMA/efa, SMB server, s390/mm, wave5, dm-verity-fec, mlx4). Parte 10 descreve bem CVE-2026-76642, 78408, 78409 e 78410.
- **Mitigação correta para CVE-2026-12064:** "Evitar o uso de URLs sem esquema com protocolos SSH (sftp, scp)" (parte 2).

- **Reconhece a ausência de correção na parte 7:** "Não há correção específica de pacote para linux-libc-dev nesta CVE". É o único trecho, entre os três locais, que afirma de modo direto que o dado não informa versão corrigida.
- **Cautela com CVEs antigas:** na parte 4, sobre CVE-2013-7445, diz "Embora tenha CVE ID antigo, deve ser verificada se ainda está presente".

Principais limitações

- **Cobertura incompleta em blocos inteiros.** Na parte 7 lista 3 de 10 CVEs (omite CVE-2026-53000, 53091, 53109, 53118, 53277, 53330 e 63879). Na parte 9 lista 3 de 10 (omite CVE-2026-89811, 89972, 90111, 90315, 97528, 98222 e 98260). Na parte 10 lista 2 dos 4 CVEs do kernel. Na parte 5 lista 8 de 10. Na parte 11 omite CVE-2026-78408; na parte 3 omite CVE-2025-69720 (libtinfo6). Como o prompt pedia "vulnerabilidades relevantes", seleção é aceitável, mas nessas partes não há critério declarado para a seleção, e as omitidas têm a mesma severidade das listadas.
- **Erros factuais de leitura:**
- CVE-2026-43185 descrita como "vulnerabilidade crítica de assinatura de dados no SMB" (parte 4). A descrição fala de "signededness bug" (erro de sinal de inteiro) que leva a heap buffer overflow em ksmbd. "Assinatura" é uma leitura equivocada da palavra.
- CVE-2026-9538 (perl-base, Archive::Tar) descrita como "buffer overflow no Perl que pode ser explorada via entrada maliciosa no comando infocmp" (parte 11). O JSON descreve exaustão de memória por cabeçalho tar com tamanho forjado; "infocmp" pertence à CVE de ncurses do mesmo bloco. Houve mistura de duas vulnerabilidades.
- CVE-2025-38421 classificada como "Out-of-Bounds Read/Write" (parte 5); a descrição é de double free.
- CVE-2026-98364 atribuída a "gestão de referências de conntrack" (parte 10); a descrição é de xfrm e net_device. Apenas CVE-2026-98320 trata de conntrack.
- **Inflação de impacto.** "Execução de código remoto" é atribuída a múltiplas CVEs cujas descrições não a sustentam: CVE-2026-46279 (parte 7, trata de warning de codetag sob configuração de debug), CVE-2026-68409, 68470, 72098, 74752 (parte 8), CVE-2026-89675 (parte 9). Na parte 1 afirma que as CVEs de util-linux podem ser exploradas "em alguns casos, remoto se Orion for exposto", sem base na descrição (vetores locais).
- **Elevação de severidade:** "Essas vulnerabilidades são críticas" (partes 1, 5, 11) para CVEs classificadas HIGH.
- **Termos sem sentido ou mal traduzidos:** "ataques como devoxy (supersede de credenciais)" (parte 1); "ataques de degradação de serviço ou de suborno (man-in-the-middle)" (parte 2); "Escape de Monta" (parte 3); "restringir newfs" (parte 3, utilitário inexistente no contexto).
- **Recomendações não aplicáveis a um operador de imagem:** "garantir que objetos sensíveis não sejam acessados após liberação", "adicionar verificações de tamanho antes do acesso" (parte 6) e "aplique patches upstream para estender o bloqueio do cgroup_mutex em pressure_write()" (parte 7) são instruções de desenvolvedor de kernel, não de correção prática. "Usar ferramentas de mitigação como KASAN" (parte 6) confunde ferramenta de depuração com mitigação.
- **Versões sem sustentação:** `util-linux=2.42.*`, `perl-base=5.40.*`, `ncurses-bin=6.5-20251213+` (parte 11). A primeira contraria a descrição de CVE-2026-76642 (afetadas até 2.42.2); a segunda é vazia (a instalada já é 5.40.1-6); a terceira usa formato de versão Debian inexistente. Na parte 1, "flags --allow-downgrades" não tem relação com o problema. Na parte 3, "atualize o pacote systemd-homed" refere-se a pacote que o JSON não lista.
- **Comentário confuso sobre datas:** "As CVEs mencionadas possuem datas (2026) que podem indicar versões futuras do kernel" (parte 7).

Qualidade da interpretação

Média-baixa. Há partes bem interpretadas (2, 6, 10) e o modelo demonstra noção de priorização por relevância para o Orion (partes 2 e 11). Mas a frequência de leituras equivocadas (signedness como assinatura, infocmp em perl, conntrack em xfrm, double free como OOB) e a tendência de concluir "execução remota de código" a partir de descrições que não a mencionam reduzem a confiabilidade. A distinção entre dado e inferência raramente é feita.

Qualidade das recomendações

Baixa-média. A recomendação dominante é "atualizar para uma versão corrigida", sem reconhecer (exceto na parte 7) que o dado não informava versão. As poucas mitigações específicas (URLs com esquema, monitorar cgroups, isolamento) são boas. As recomendações de nível de código-fonte do kernel, as versões fictícias e a confusão sobre KASAN tiram utilidade prática.

Informações não sustentadas

- "Assinatura de dados no SMB" para CVE-2026-43185.
- "Buffer overflow ... via infocmp" para CVE-2026-9538.
- "Remoto se Orion for exposto" para util-linux.
- "Execução de código remoto" para CVE-2026-46279, 68409, 68470, 72098, 74752, 89675.
- "Conntrack" para CVE-2026-98364.
- Versões `2.42.*`, `5.40.*`, `6.5-20251213+`.
- "devoxy", "suborno (man-in-the-middle)", "newfs", "KASAN como mitigação".
- "Vulnerabilidades críticas" para itens HIGH.

Síntese

O DeepSeek R1 acerta IDs e pacotes e, em blocos mistos, prioriza com justificativa. Porém, deixa de listar a maioria dos itens em dois blocos, comete erros de leitura relevantes, infla impactos para execução remota de código sem base e mistura recomendações operacionais com instruções de desenvolvimento de kernel. Média 5,33, abaixo do limiar satisfatório.

Qwen 3.5

Critério	Nota
Vulnerabilidades relevantes	7/10
Impacto provável	6/10
Recomendações de correção	7/10
MÉDIA	**6,67/10**

Principais acertos

- **Cobertura completa em todos os 11 blocos**, com pacote e versão instalada corretos. 46 IDs distintos, todos existentes no JSON. Nas partes 5, 8 e 9 o modelo lista os 10 CVEs do bloco com uma linha de impacto para cada, e o mapeamento ao subsistema é correto em praticamente todos (PCI/pwrctrl, nouveau, JFS, AMD PMF, tracepoints, ptp/ocp, mt7915, iommu/s390, F2FS, KFD; mac80211, xfrm, ipmi, dm-verity, bnxt,

iommufd, sctp, smb; smb client, nfsd, KFD TLB, NVMe SRCU, ip6mr, PCI lockdown, qla2xxx, KEYS, timers POSIX).

- **Leitura correta de CVEs que outros modelos erraram:** CVE-2026-43185 descrita como "Heap buffer overflow no ksmbd (explorável)" (parte 4), o que corresponde ao final da descrição ("the attacker can then achieve a heap buffer overflow"). CVE-2026-9538 descrita como "Negação de serviço (DoS) por consumo excessivo de memória via cabeçalhos .tar malformados" (parte 11), exatamente a descrição.
- **Apresentação que destaca o essencial.** Uso de tabelas com ID, pacote, versão e severidade; marcação do único CRITICAL do bloco 4; agrupamento do impacto por categoria (escalada de privilégios, DoS, quebra de isolamento).
- **Mitigações sustentadas para util-linux:** "revise as entradas /etc/fstab e desabilite opções X-mount perigosas (idmap, owner, subdir) até a correção" (parte 1); "evite configurações complexas de montagem (fstab) que utilizem opções experimentais como X-mount.owner" (parte 2); revisão de fstab repetida nas partes 4 e 11. Essas mitigações derivam diretamente das descrições.
- **Reconhecimento, ainda que parcial, de que a correção pode não existir:** "Enquanto aguarda atualizações (se não estiver disponível)" (parte 1); na parte 10 usa a informação da descrição: "versões posteriores a 2.41.5 ou 2.42.2, conforme especificado nas descrições".
- **Passos de verificação práticos:** `dpkg -l linux-libc-dev` para confirmar versão superior a 6.12.74-2 (partes 8 e 9); verificação de que util-linux foi atualizado porque todas as CVEs apontam para ele (parte 2).

Principais limitações

- **Inflação recorrente de "remoto".** CVE-2025-69720 (infocmp, ferramenta local de linha de comando) descrita como "execução remota ou local de código (RCE)" (parte 3) e "Execução de Código Remoto/Local" (parte 11); CVE-2025-68735 (drm/panthor, título do JSON: "Privilege escalation") descrita como "permite execução remota de código" (parte 6); CVE-2021-3847 e 3864 (OverlayFS, SUID) incluídas em "usuários locais ou atacantes remotos elevem privilégios" (parte 4); "Risco de Escape de Privilégios Locais e Execução de Código Remoto (RCE)" como impacto genérico do bloco 8; "Possibilidade de Execução Remota de Código (RCE)" para o bloco 10. As descrições desses itens apontam vetores locais ou não mencionam execução remota.
- **Ausência de leitura do contexto de contêiner.** Recomenda "apt dist-upgrade -y && reboot" e "verifique uname -r" (parte 5), "reiniciar o servidor para carregar ... o kernel corrigido" (parte 7), "reboot obrigatório" (parte 8), "systemctl restart networking" (parte 10) e "isolar a interface de rede do módulo Wi-Fi" (parte 4). Em uma imagem de contêiner, `linux-libc-dev` são headers; o kernel em execução é do host, e reboot ou reinício de serviços de rede dentro da imagem não corrigem nada. Nenhuma parte faz a distinção.
- **Pacotes e detalhes não presentes nos dados:** "firmware-linux-non-free" (parte 6); "linux-image, linux-modules, linux-headers" como pacotes a atualizar (partes 5, 6, 7) sem que o JSON os liste; "exposição de informações ... via /proc" (parte 8) não consta da descrição de CVE-2026-89631.
- **Leituras pontuais imprecisas:** "SMB Server (IBM)" para CVE-2026-31536 (parte 6), em que "IB" refere-se a InfiniBand (IB_SEND_SIGNALED); "ataques de injeção via rede" para CVE-2026-53000/53091 (parte 7) vai além da descrição.
- **Recomendações genéricas repetidas:** "monitoramento contínuo", "atualização automática", "verificação de hash/checksums" aparecem em quase todas as partes sem conexão específica com as CVEs do bloco. "Rollback e Verificação" (parte 9) nomeia uma seção que não trata de rollback.
- **Comentário sem função:** "(e passadas, dado o ano 2026 nos IDs)" (parte 2).

Qualidade da interpretação

Média. O mapeamento CVE-subsistema-tipo de falha é consistentemente correto, e dois casos difíceis (43185 e 9538) foram lidos melhor do que pelos demais locais. O ponto fraco é a transformação sistemática de "pode permitir execução de código" em "execução remota de código", e a ausência de qualquer leitura do que significa

`linux-libc-dev` em uma imagem de contêiner. A proporcionalidade é razoável em util-linux e curl, e fraca no kernel.

Qualidade das recomendações

Boa dentro do que o insumo permitia. Os comandos são aplicáveis (`apt update && apt upgrade <pacotes>`), as mitigações de fstab são corretas e específicas, e há passos de verificação pós-correção. O que reduz a nota é o conjunto de orientações que só fazem sentido em um host (reboot, systemctl, Wi-Fi) e a citação de pacotes que o JSON não lista.

Informações não sustentadas

- "Execução remota" para CVE-2025-69720, CVE-2025-68735, CVE-2021-3847/3864 e, de forma genérica, para os blocos 8 e 10.
- "firmware-linux-non-free", "linux-image", "linux-modules", "linux-headers".
- "Exposição via /proc" (CVE-2026-89631).
- "SMB Server (IBM)".
- "Ataques de injeção via rede" (CVE-2026-53000/53091).

Síntese

O Qwen 3.5 entregou a cobertura mais completa e organizada entre os locais, com leitura correta de casos difíceis e mitigações sustentadas para util-linux. Perde pontos por inflar sistematicamente o vetor para "remoto" e por recomendar ações de host (reboot, reinício de rede) sem perceber o contexto de contêiner. Média 6,67, próxima mas abaixo do limiar satisfatório.

COMPARAÇÃO CONSOLIDADA

Critério	Granite 4.2	DeepSeek R1	Qwen 3.5	GPT-6 Astra Alto
Vulnerabilidades relevantes	7	6	7	8
Impacto provável	6	5	6	9
Recomendações de correção	5	5	7	9
MÉDIA	**6,00**	**5,33**	**6,67**	**8,67**

Lembrete: as notas dos modelos locais refletem o desempenho sobre blocos de ~10 vulnerabilidades sem correção informada; a nota do GPT reflete o desempenho sobre o conjunto completo de 832 ocorrências com `FixedVersion` e metadados. A seção 0.4 descreve a diferença.

COMPARAÇÃO LOCAL × NUVEM

Granite 4.2 × GPT-6 Astra Alto

- **Precisão:** ambos acertam todos os IDs e pacotes citados. O GPT não tem afirmação contrariada pelo JSON; o Granite tem várias (versões 2.42.3, 2.41.6, "kernel 6.5+", "Debian já inclui fixes", "Bookworm", AT_SYMLINK_FOLLOW). Vantagem clara do GPT.

- **Profundidade:** o Granite explica cada CVE do bloco e, na parte 7, aprofunda o cenário de contêiner com kernel do host. O GPT aprofunda por família de pacote e por pré-condição (RSA-PSK, 32 bits, SUID/fstab). Profundidade comparável em natureza; o GPT é mais consistente.
- **Interpretação:** o Granite acerta a maioria e erra em pontos críticos (parte 8, inversão do status). O GPT mantém proporcionalidade do início ao fim.
- **Contextualização:** o Granite tem a melhor observação de contexto entre os locais (kernel do host), mas apenas em uma parte; nas outras trata headers como kernel e sugere testes de áudio USB e CXL no Orion. O GPT contextualiza com arquitetura, usuário, entrypoint e distinção headers/kernel. Vantagem do GPT.
- **Recomendações:** o Granite mistura recomendações sólidas (fstab, isolamento, host) com versões fictícias e orientações erradas. O GPT entrega versão exata do JSON por pacote e mitigação específica por item sem correção. Vantagem grande do GPT.
- **Informações não sustentadas:** Granite tem ao menos 10 ocorrências; GPT, nenhuma.
- **Clareza:** o Granite expõe raciocínio e rascunhos; o GPT entrega uma página estruturada. Vantagem grande do GPT.

Classificação da diferença: grande. Justificativa: embora o Granite identifique corretamente o que recebeu e tenha uma observação de contexto excelente, a diferença de 4 pontos em recomendações, de 3 em impacto e a presença de informações não sustentadas versus ausência total no GPT caracterizam uma diferença de nível, não apenas de grau. Parte dessa diferença, porém, decorre do insumo: o Granite não tinha `FixedVersion` para citar, e preencheu a lacuna com versões de memória. Se tivesse o campo, parte das invenções provavelmente não ocorreria.

DeepSeek R1 × GPT-6 Astra Alto

- **Precisão:** IDs e pacotes corretos em ambos. O DeepSeek erra o conteúdo de quatro CVEs (43185, 9538, 38421, 98364); o GPT não erra nenhuma. Vantagem clara do GPT.
- **Profundidade:** o DeepSeek alterna partes detalhadas (2, 6, 8) com partes que listam 3 de 10 itens sem critério declarado (7, 9). O GPT é uniformemente profundo nos itens que escolhe e declara que a seleção é priorizada.
- **Interpretação:** o DeepSeek converte possibilidade em certeza ("execução de código remoto") com frequência e eleva HIGH a "crítico". O GPT faz o oposto: ressalva pré-condições e marca inferências.
- **Contextualização:** o DeepSeek faz julgamentos de relevância para o Orion (perl e ncurses como menos relevantes) e menciona o Orion em várias partes, mas não lê o contexto de contêiner. O GPT lê arquitetura, usuário e natureza do pacote de headers. Vantagem do GPT.
- **Recomendações:** o DeepSeek recomenda atualizar sem versão (correto dado o insumo) mas acrescenta instruções de desenvolvedor de kernel, versões fictícias e "KASAN como mitigação". O GPT entrega versões, mitigações e processo. Vantagem grande do GPT.
- **Informações não sustentadas:** DeepSeek tem mais de 10; GPT nenhuma.
- **Clareza:** o DeepSeek é organizado e legível, com seções claras. O GPT também. Diferença pequena neste aspecto.

Classificação da diferença: grande. Justificativa: a diferença de 3,33 pontos na média é a maior entre os pares. O DeepSeek tem bons momentos de priorização, mas a soma de omissões não justificadas, erros de leitura e inflação de impacto o distancia do nível do GPT em dois dos três critérios.

Qwen 3.5 × GPT-6 Astra Alto

- **Precisão:** IDs e pacotes corretos em ambos. O Qwen acerta os dois casos difíceis (43185 e 9538). Suas imprecisões são de impacto ("remoto") e de pacotes inexistentes no JSON, não de identificação. O GPT é preciso em tudo. Vantagem moderada do GPT.
- **Profundidade:** o Qwen explica cada um dos ~10 itens de cada bloco com uma linha correta de impacto; o GPT explica ~30 itens selecionados com mais contexto cada. Profundidade equivalente em natureza, diferente em alcance por causa do insumo.

- **Interpretação:** o Qwen infla o vetor para "remoto" em várias partes; o GPT não. O Qwen não distingue dado de inferência; o GPT distingue. Vantagem do GPT.
- **Contextualização:** o Qwen não lê o contexto de contêiner (reboot, systemctl, Wi-Fi). O GPT lê. Vantagem clara do GPT.
- **Recomendações:** o Qwen entrega comandos aplicáveis, mitigações de fstab corretas e verificação pós-correção. O GPT entrega o mesmo com versões exatas e tratamento explícito dos itens sem correção. Diferença moderada, parcialmente explicada pela ausência de `FixedVersion` no insumo do Qwen.
- **Informações não sustentadas:** Qwen tem cerca de 6, concentradas em "remoto" e nomes de pacotes de kernel; GPT nenhuma.
- **Clareza:** ambos são claros. O Qwen usa tabelas, o GPT usa itens numerados densos. Equivalentes.

Classificação da diferença: moderada. Justificativa: 2,00 pontos de diferença na média. O Qwen fica a 1 ponto do GPT em identificação e a 2 em recomendações; a distância maior (3 pontos) está em impacto, pela inflação de "remoto" e pela ausência de leitura de contexto. Não há erro de identificação nem invenção de versão; os problemas são de calibração.

Diferença de nível entre modelos locais e modelo de nuvem

1. Onde o GPT-6 Astra Alto demonstrou vantagem clara

- **Controle de inferência.** O GPT marca explicitamente o que é dado e o que é inferência, ressalva pré-condições e não eleva severidade. Nenhum modelo local faz isso de forma sistemática.
- **Uso do contexto da imagem.** Arquitetura (amd64 versus CVE de 32 bits), usuário `nobody`, natureza do pacote `linux-libc-dev`. Apenas o Granite, em uma parte, toca no último ponto.
- **Zero informações não sustentadas.** Os três locais introduziram versões, pacotes, caminhos ou termos ausentes dos dados.
- **Tratamento diferenciado do que não tem correção.** O GPT separa e mitiga; os locais, em geral, recomendam "atualizar para versão corrigida" mesmo quando o dado não informa versão.
- **Síntese.** O GPT entregou uma página que responde ao pedido de concisão sem sacrificar o essencial. Isso só foi possível porque ele tinha o conjunto completo; ainda assim, a seleção foi bem feita.

2. Onde os modelos locais chegaram próximos

- **Identificação de IDs e associação a pacotes.** Nenhum dos quatro modelos inventou IDs ou errou pacotes. Granite e Qwen listaram tudo o que receberam, com precisão.
- **Paráfrase de descrições.** Nas partes em que leram a descrição, Granite e Qwen (e o DeepSeek nas partes 2, 6 e 10) resumiram o problema de forma fiel ao texto do JSON.
- **Mitigações derivadas da descrição.** Os três locais chegaram a "evitar URL sem esquema com --proto-default" para CVE-2026-12064 e "revisar fstab / opções X-mount" para util-linux, as mesmas mitigações que o GPT propôs.

3. Onde algum modelo local apresentou resultado equivalente ou superior em determinado aspecto

- **Granite 4.2, parte 7:** a observação de que o contêiner usa o kernel do hospedeiro e que o host deve ser corrigido, não dependendo de atualização dentro do contêiner, é equivalente à distinção que o GPT faz sobre `linux-libc-dev` e é a observação de contexto mais relevante para 695 das 832 ocorrências.

- **Qwen 3.5, partes 4 e 11:** leu corretamente CVE-2026-43185 (heap overflow em ksmbd) e CVE-2026-9538 (exaustão de memória via cabeçalho tar). O GPT, para 43185, usou apenas a frase genérica "corrupção de memória e falhas de concorrência" e não citou 9538.
- **DeepSeek R1, parte 11:** classificou perl e ncurses como "menos relevantes para o Orion" com justificativa de contexto de uso. O GPT não fez julgamento de relevância por aplicação para esses pacotes; aliás, não os citou.
- **Cobertura das HIGH sem correção:** Granite e Qwen citaram CVE-2026-78408, 78409, 54369, 16742 e 69720, todas omitidas pelo GPT. Nesse recorte específico, os locais cobriram mais.

4. Erros mais frequentes nos modelos locais

1. **Transformar possibilidade em certeza, especialmente "execução remota de código"**, para CVEs cujas descrições indicam vetor local ou não mencionam execução remota (DeepSeek e Qwen, repetidamente).
2. **Preencher a ausência de `FixedVersion` com versões de memória ou inventadas** (Granite e DeepSeek).
3. **Tratar `linux-libc-dev` como o kernel em execução dentro do contêiner**, gerando recomendações de reboot, reinício de rede ou isolamento de Wi-Fi (Qwen em quase todas as partes do kernel; Granite e DeepSeek em várias).
4. **Não declarar que o dado não informa correção**, quando essa era a condição de 100% do insumo (DeepSeek fez isso uma vez; Granite e Qwen, nunca de forma direta).
5. **Leituras equivocadas de termos técnicos** (signedness como assinatura, IB como IBM, infocmp atribuído a perl).
6. **Recomendações genéricas repetidas sem ligação com o bloco** (monitoramento, atualização automática, checksums) e, no DeepSeek, instruções de desenvolvedor de kernel apresentadas como correção prática.

5. Erros que também aparecem no modelo de nuvem

- **Omissão de vulnerabilidades sem correção que exigiriam mitigação explícita** (CVE-2026-78408, 78409, 54369, 16742, 69720, 9538). O GPT fez uma seleção e a declarou, mas a seleção deixou de fora metade das HIGH sem correção fora do kernel.
- **Versão de correção que não cobre todas as CVEs do pacote** (libssh2: citou u1, mas CVE-2026-58050 exige u2). É o mesmo tipo de problema de "versão insuficiente" visto nos locais, em escala muito menor e sem invenção.
- **Tratamento agregado do kernel sem uso de informação disponível** (não citou as versões 6.12.85-1 e seguintes nem o número de CVEs do kernel sem correção).

6. Onde está principalmente a diferença observada

Dimensão	Diferença observada
Precisão (IDs, pacotes)	**Pequena.** Todos acertaram IDs e pacotes.
Capacidade de interpretação	**Moderada.** Os locais interpretam bem a maior parte, mas erram termos e inflam vetores.
Contextualização	**Grande.** O GPT usa metadados e distingue headers de kernel; os locais, com uma exceção pontual, não.
Recomendações	**Grande para Granite e DeepSeek, moderada para Qwen.** Versões exatas e tratamento de "sem correção" versus versões inventadas ou "atualize" genérico. Parte dessa diferença é atribuível ao insumo.

Dimensão	Diferença observada
Síntese	**Não comparável de forma justa.** O GPT tinha o conjunto completo e podia sintetizar; os locais tinham blocos isolados e não podiam. Dentro de cada bloco, Qwen e DeepSeek sintetizaram razoavelmente; o Granite não.
Controle de inferências	**Grande.** É a dimensão em que o GPT mais se distancia: ressalvas sistemáticas versus afirmações sem ressalva.

Conclusão desta seção: a diferença de nível não está em "saber quais são as vulnerabilidades" (todos sabem), mas em **o que se faz com elas**: calibrar o impacto ao que o dado sustenta, usar o contexto da imagem e não preencher lacunas do dado com conteúdo não sustentado.

COBERTURA × SÍNTESE

- **Cobrir muito:** Granite e Qwen listaram todos os itens de cada bloco. Isso é adequado ao insumo (10 itens por chamada, todos sem correção) e ao pedido de "ID e pacote". Mas cobertura total dentro do bloco não gerou, por si, qualidade: o Granite cobriu tudo e ficou com média 6,00; o Qwen cobriu tudo e ficou com 6,67. A diferença entre eles não está na cobertura, mas na precisão das recomendações e na quantidade de informação não sustentada.
- **Selecionar e sintetizar:** o GPT cobriu 30 de 744 CVEs distintos e declarou que fez uma seleção priorizada. A seleção foi boa (todas as CRITICAL, famílias de maior impacto, itens sem correção de curl e util-linux), mas deixou de fora HIGH sem correção. Sua média alta vem da qualidade do que foi dito sobre cada item selecionado, não do número de itens.
- **O DeepSeek ilustra o risco oposto:** em dois blocos selecionou 3 de 10 sem declarar critério, e as 7 omitidas tinham a mesma severidade das 3 citadas. Seleção sem critério declarado é omissão, não síntese.
- **Conclusão:** nem o relatório de 40 páginas (Granite) nem o de 1 página (GPT) recebeu nota por tamanho. O Granite perdeu pontos por conteúdo não sustentado e por legibilidade; o GPT ganhou pontos por precisão e contexto, e perdeu por omissões específicas. O relatório de 14 páginas (DeepSeek) ficou abaixo do de 16 (Qwen) por razões de conteúdo, não de extensão.

CONCISÃO

O prompt pediu "Seja conciso e direto ao ponto".

- **GPT-6 Astra Alto:** atendeu. Uma página, sete itens numerados agrupados por família de pacote, uma seção de ação prática e notas de limitação. Não há repetição. O risco de síntese excessiva se materializou nas omissões já descritas (HIGH sem correção fora do kernel, krb5, nghttp2), mas o relatório declara que é uma seleção.
- **Qwen 3.5:** atendeu razoavelmente. Cada parte tem a estrutura pedida, com tabelas compactas. Há repetição de recomendações genéricas entre partes (monitoramento, atualização automática, checksums), que são texto desnecessário, mas o conteúdo específico é direto.
- **DeepSeek R1:** atendeu parcialmente. As partes são curtas e organizadas, mas há frases de preenchimento ("Essas vulnerabilidades são críticas e exigem correções urgentes") e, nas partes 7 e 9, a concisão veio por omissão de 70% dos itens, não por síntese.
- **Granite 4.2:** não atendeu. O relatório exibe o raciocínio interno em inglês antes de cada resposta e, em várias partes, dois ou três rascunhos completos antes da versão final (a parte 1 contém a lista de CVEs três vezes). A resposta final de cada parte é, por si, razoavelmente concisa, mas o documento entregue é o oposto de

direto ao ponto. É possível que isso decorra da configuração da execução (não supressão de tokens de raciocínio), mas o artefato avaliado é o relatório como foi produzido.

Equilíbrio entre cobertura e objetividade: o GPT e o Qwen chegaram mais perto, por caminhos diferentes (seleção declarada versus cobertura completa em tabelas). O DeepSeek sacrificou cobertura sem declarar. O Granite sacrificou objetividade.

RANKING

- 1º — GPT-6 Astra Alto — 8,67
- 2º — Qwen 3.5 — 6,67
- 3º — Granite 4.2 — 6,00
- 4º — DeepSeek R1 — 5,33

> O ranking compara a qualidade dos relatórios produzidos, mas os quatro modelos não foram executados sob condições de entrada completamente idênticas. Os modelos locais analisaram, em 11 chamadas separadas, apenas as vulnerabilidades sem correção informada, sem o campo `FixedVersion` e sem metadados da imagem; o GPT-6 Astra Alto analisou o conjunto completo de 832 ocorrências em uma única chamada, com versões de correção e metadados. Apenas o GPT-6 Astra Alto atingiu o limiar de 7,00.

QUESTÕES FINAIS

1. O GPT-6 Astra Alto apresentou nível de análise superior aos modelos locais? Sim. Superou os três em todos os critérios, com diferença de 1 a 2 pontos em identificação, 3 a 4 em impacto e 2 a 4 em recomendações. A superioridade é mais nítida em controle de inferência e contextualização, e menos nítida em identificação de IDs e pacotes, em que os quatro foram precisos. Parte da vantagem em recomendações é explicada pelo insumo (presença de `FixedVersion` e metadados), não apenas pelo modelo.

2. Qual modelo local ficou mais próximo do nível apresentado pelo GPT-6 Astra Alto? O Qwen 3.5, com média 6,67 (diferença de 2,00). Ficou a 1 ponto em identificação e a 2 em recomendações. Sua maior distância foi em impacto (3 pontos), pela inflação de "remoto" e pela ausência de leitura do contexto de contêiner.

3. Em qual dos três critérios ocorreu a maior diferença entre local e nuvem? Em **recomendações de correção**, considerando Granite e DeepSeek (4 pontos cada), e em **impacto provável**, considerando a média dos três locais (5,67 contra 9, diferença de 3,33). Em recomendações, a média dos locais foi 5,67 contra 9, também 3,33. Os dois critérios empatam na média; o de recomendações tem a maior diferença individual. Em recomendações, a diferença é parcialmente atribuível ao insumo; em impacto, não há atenuante de insumo, pois as descrições estavam disponíveis a todos.

4. Em qual critério os modelos locais ficaram mais próximos? Em **vulnerabilidades relevantes**: média dos locais 6,67 contra 8 do GPT, diferença de 1,33. Nenhum modelo inventou IDs ou errou pacotes, e dois locais cobriram integralmente o que receberam.

5. Os modelos locais demonstraram capacidade útil para interpretação de relatórios de vulnerabilidade? Sim, com reservas. Os três identificaram corretamente IDs e pacotes, resumiram descrições com fidelidade na maior parte dos casos e derivaram mitigações corretas das descrições (URL com esquema, revisão de fstab). O Granite produziu uma observação de contexto de contêiner de alto valor; o Qwen leu corretamente casos técnicos difíceis. As reservas são: inflação de impacto, preenchimento de lacunas com informação não sustentada e ausência de

leitura de contexto de imagem. Para uso prático, as saídas locais exigiriam revisão humana antes de orientar ação, especialmente nas versões de correção e nos vetores de ataque afirmados.

6. A diferença observada justifica afirmar que modelos locais são inadequados para a tarefa? Não. Nenhum dos três atingiu 7,00, mas o Qwen ficou a 0,33 do limiar, e a parte da diferença atribuível ao insumo (ausência de `FixedVersion`, ausência de metadados, fragmentação em blocos) não foi isolada neste teste. Os erros mais frequentes dos locais (inflação de "remoto", versões inventadas) são erros de calibração, não de incapacidade de leitura, e são o tipo de erro que instrução explícita ou revisão humana tendem a mitigar. A afirmação sustentada pelos dados é mais restrita: **nas condições do Teste 03, os três modelos locais produziram análises abaixo do nível satisfatório e abaixo do nível do modelo de nuvem nas condições do Teste 04, com a menor distância no Qwen 3.5.**

CONCLUSÃO ACADÊMICA

Capacidade demonstrada pelos modelos locais. Nas condições do Teste 03 (blocos de aproximadamente 10 vulnerabilidades sem correção informada, 11 chamadas independentes, sem metadados da imagem), Granite 4.2, DeepSeek R1 e Qwen 3.5 demonstraram capacidade de identificar corretamente identificadores CVE e pacotes afetados, sem fabricar identificadores, e de parafrasear descrições técnicas com fidelidade na maioria dos casos. Dois deles (Granite e Qwen) cobriram integralmente cada bloco; os três derivaram das descrições mitigações corretas para curl e util-linux. Observações pontuais de alto valor foram registradas: a distinção entre pacote de headers e kernel do hospedeiro (Granite, parte 7) e a leitura correta de vulnerabilidades tecnicamente densas (Qwen, CVE-2026-43185 e CVE-2026-9538). As médias obtidas foram 6,00 (Granite), 5,33 (DeepSeek) e 6,67 (Qwen), todas abaixo do limiar de 7,00, com os principais déficits em calibração de impacto (conversão de possibilidade em certeza, sobretudo "execução remota de código"), em preenchimento de lacunas do dado com versões ou pacotes não sustentados e em ausência de leitura do contexto de imagem de contêiner.

Desempenho do modelo de nuvem. Nas condições do Teste 04 (conjunto completo de 832 ocorrências HIGH/CRITICAL em uma única chamada, com versões de correção e metadados), o GPT-6 Astra Alto obteve média 8,67. Todas as suas afirmações verificáveis (totais, IDs, pacotes, versões, status, arquitetura, usuário) conferem com o JSON. Identificou as 12 CRITICAL, usou corretamente versões de correção diferenciadas por CVE, separou itens com e sem correção e propôs mitigações específicas para os últimos, e contextualizou os achados com metadados da imagem. Suas limitações foram a omissão de parte das HIGH sem correção fora do kernel e de pacotes de menor volume, uma versão de libssh2 insuficiente para cobrir todas as CVEs do pacote e o tratamento apenas agregado do kernel.

Diferença de nível observada. A diferença entre o melhor modelo local e o modelo de nuvem foi de 2,00 pontos (moderada); entre os demais locais e o modelo de nuvem, de 2,67 e 3,33 pontos (grande). A diferença concentra-se em controle de inferência, contextualização e qualidade das recomendações, e é pequena em identificação de vulnerabilidades. O modelo de nuvem não apresentou informações não sustentadas; os três locais apresentaram.

Limitações metodológicas da comparação. Esta comparação não é controlada. Os modelos locais e o modelo de nuvem receberam insumos diferentes em conteúdo (apenas vulnerabilidades sem correção versus conjunto completo), em estrutura (11 blocos independentes versus uma chamada única), em campos disponíveis (sem versus com `FixedVersion` e metadados) e, possivelmente, em data de varredura (vulnerabilidades do kernel hoje corrigidas em 6.12.113-1 apareciam como sem correção no Teste 03). Parte da diferença observada em recomendações é diretamente atribuível a essas condições, e a parcela atribuível ao modelo não foi isolada. A comparação também não mede velocidade, custo, arquitetura ou reprodutibilidade. Os resultados referem-se exclusivamente à imagem fiware/orion (Debian 13.4), ao scanner Trivy 0.74.0, ao filtro HIGH/CRITICAL, ao prompt base utilizado e às quatro execuções específicas avaliadas. Não se generalizam para outros modelos locais, outros modelos de nuvem, outras imagens, outros scanners, outros filtros de severidade ou outras configurações de chamada. A conclusão sustentada pelos dados é que, **nestas condições**, o modelo de nuvem produziu análise de

nível superior, que a diferença é maior em calibração e contexto do que em identificação, e que o modelo local mais próximo (Qwen 3.5) ficou a uma distância que não autoriza, por si, a afirmação de inadequação dos modelos locais para a tarefa.

ANEXO A — Verificação das afirmações do GPT-6 Astra Alto contra o JSON

Afirmação do relatório	Valor no JSON	Resultado
832 ocorrências, 820 HIGH, 12 CRITICAL	832 / 820 / 12	Confere
744 CVEs distintos	744	Confere
714 com FixedVersion; 118 sem	714 / 118	Confere
Imagem amd64	`architecture: amd64`	Confere
Usuário nobody configurado	`config.User: nobody`	Confere
GnuTLS: atualizar 3.8.9-3+deb13u2 → 3.8.9-3+deb13u4	FixedVersion das 5 CVEs = 3.8.9-3+deb13u4	Confere
CVE-2026-42010: bypass de autenticação em servidores RSA-PSK	Descrição menciona RSA-PSK e authentication bypass	Confere
OpenSSL: atualizar para 3.5.7-1~deb13u3	45447 → 3.5.6-1~deb13u2; 14456 → 3.5.7-1~deb13u2; 84782 → 3.5.7-1~deb13u3	Confere (maior versão cobre as três)
curl: atualizar para 8.14.1-2+deb13u7	6276 → deb13u4; 8927, 92392 → deb13u7	Confere
CVE-2026-12064 e 8458 sem correção	status `affected`, FixedVersion vazio	Confere
pcre2: atualizar para 10.46-1~deb13u3	86145 → deb13u2; 103111 → deb13u3	Confere
sqlite: atualizar para 3.46.1-7+deb13u2	FixedVersion = 3.46.1-7+deb13u2	Confere
libssh2 CVE-2026-55200: correção em 1.11.1-1+deb13u1	FixedVersion = 1.11.1-1+deb13u1	Confere; mas CVE-2026-58050 (mesmo pacote, não citada) exige deb13u2
perl-base: atualizar 5.40.1-6 → 5.40.1-6+deb13u1	7 das 8 CVEs → deb13u1; CVE-2026-9538 `fix_deferred`	Confere; 9538 não mencionada
CVE-2026-8376: overflow em builds de 32 bits	Descrição: "on 32-bit builds"	Confere
util-linux: correção 2.41.5-0+deb13u1	FixedVersion das 4 corrigidas = 2.41.5-0+deb13u1	Confere
CVE-2026-76642 e 78410 sem correção	status `affected`	Confere; 78408 e 78409 também sem correção e não citadas
Kernel: 695 ocorrências	695	Confere
Kernel: 7 CRITICAL listadas	CVE-2026-43011, 43037, 43185, 53215, 63825, 90037, 93221	Confere (lista exata)

ANEXO B — Composição dos blocos do Teste 03 reconstruída a partir dos relatórios locais

Bloco	Conteúdo (IDs e pacotes)
1	CVE-2026-76642, 78408, 78409, 78410 (bsdutils, libblkid1); CVE-2026-12064, 8458 (curl); CVE-2026-54369 (libacl1)
2	CVE-2026-78410 (libblkid1, liblastlog2-2); CVE-2026-12064, 8458 (libcurl4t64); CVE-2026-76642, 78408, 78409 (liblastlog2-2, libmount1)
3	CVE-2026-78410 (libmount1, libsmartcols1); CVE-2026-76642, 78408, 78409 (libsmartcols1, libuuid1); CVE-2026-16742 (libsystemd0, libudev1); CVE-2025-69720 (libtinfo6)
4	CVE-2026-78409, 78410 (libuuid1); CVE-2026-43185 (CRITICAL) e CVE-2013-7445, 2019-19449, 2019-19814, 2021-3847, 2021-3864, 2024-21803, 2024-58015 (linux-libc-dev)
5	10 CVEs 2025 de linux-libc-dev (38137 a 68174)
6	10 CVEs de linux-libc-dev (2025-68735, 2026-23102 a 46181)
7	10 CVEs de linux-libc-dev (2026-46279 a 64283)
8	10 CVEs de linux-libc-dev (2026-68409 a 89631)
9	10 CVEs de linux-libc-dev (2026-89633 a 98260)
10	CVE-2026-98320, 98323, 98364, 98378 (linux-libc-dev); CVE-2026-76642, 78408, 78409, 78410 (login, mount)
11	CVE-2026-78409, 78410 (mount); CVE-2025-69720 (ncurses-base, ncurses-bin); CVE-2026-9538 (perl-base); CVE-2026-76642, 78408, 78409, 78410 (util-linux)

Todas as entradas acima têm, no JSON do Teste 04, status `affected` ou `fix_deferred`, exceto 11 CVEs do kernel (entre elas CVE-2025-38204, 2026-72463, 89633, 89638, 89972, 97528, 98222, 98260, 98320, 98323, 98378) que hoje constam como corrigidas em 6.12.113-1 e que, no Teste 03, ainda não tinham correção informada. Isso confirma que o insumo dos modelos locais foi o subconjunto sem correção da varredura da época.

ANEXO C — Cobertura por bloco (itens citados / itens do bloco)

Bloco	Granite 4.2	DeepSeek R1	Qwen 3.5
1	7/7	7/7	7/7
2	6/6	6/6	6/6
3	6/6	5/6	6/6
4	10/10	10/10	10/10
5	10/10	8/10	10/10
6	10/10	10/10	10/10
7	10/10	3/10	10/10
8	10/10	10/10	10/10
9	10/10	3/10	10/10
10	8/8	6/8	8/8
11	6/6	5/6	6/6

Documento produzido exclusivamente a partir dos cinco arquivos indicados, sem consulta a fontes externas.